

账号权限与信息安全管理规范

启明智联科技（示例公司）内部资料 - 仅用于教学与RAG项目演示

1. 账号原则

员工账号必须实名申请，不允许多人共用同一管理员账号。管理员账号仅用于运维，不用于日常办公。

2. 密码要求

密码长度至少 12 位，建议包含大小写字母、数字和特殊字符。严禁使用姓名、手机号、公司名称或连续数字作为密码。重要系统每 90 天至少更换一次密码。

3. 权限最小化

权限按照岗位分配，只授予完成工作所必需的权限。员工调岗后应在 1 个工作日内调整权限，离职账号应在离职当日禁用。

4. API Key 管理

API Key 属于敏感凭证，不得写入公开代码仓库、截图或聊天记录。项目应使用环境变量或密钥管理服务保存。发生泄露后必须立即禁用旧 Key 并创建新 Key。

5. 文档分级

公开资料可对外共享；内部资料仅限公司员工；敏感资料仅限授权项目组。RAG 知识库不得导入密码、私钥、客户身份证、银行卡等高敏感数据。

6. 日志审计

关键系统应记录登录、权限变更、文档上传和管理员操作日志。安全日志建议至少保留 180 天，并限制普通用户删除。